Steloom / LegalMAS — Architecture

Version 1.1 · 2026-10-27 · VC Technical Due Diligence

2026-10-27

Steloom / LegalMAS — Architecture
1. Purpose & scope
2. System context
3. In-house vs 3rd-party
4. Document → DD Grid path
5. LLM architecture
6. Office-converter microservice
7. Versioning & reproducibility
8. Team & ownership
9. Manual vs automated operations
10. Technical debt & roadmap
11. Known limitations
12. Out of scope (of this document)

Steloom / LegalMAS — Architecture

Document: Steloom_Architecture (VC Technical Due Diligence)
Version: 1.1 **Date:** 2026-10-27 **Audience:** Technical VC (ex-CTO, ex-engineer), pre-seed technical due diligence **Snapshot:** audited baseline `f22e3ba`; HEAD at completion `e1325f9` (deployed demo at `e1325f9`, 2026-10-26T17:13:48 UTC) **Companion to:** `TECHNICAL_OVERVIEW.md` (full audit-grade detail), `DIAGRAMS.md` (standalone diagrams), `QUALITY_AND_RISKS.md` (51 risks, 0 HIGH open), `Steloom_Product_Overview.md` (product narrative, v1.1)

This is a compact architecture document for VC technical diligence. Full audit-grade detail is in `TECHNICAL_OVERVIEW.md`. Diagrams are reproduced from `DIAGRAMS.md` §1 and §2. No claims beyond code at HEAD `e1325f9`.

---

1. Purpose & scope

Steloom (LegalMAS) is a multi-tenant SaaS for AI-assisted legal review of document sets — primarily ongoing contract / compliance review for mid-market in-house legal teams (≥50 new legal documents flowing through review), with M&A-style due diligence as an adjacent use case. The core product path:

`upload → language discovery → layout & PII → structure (segmentation + clause tree) → chunk → classify → playbook checks → DD Grid → export`.

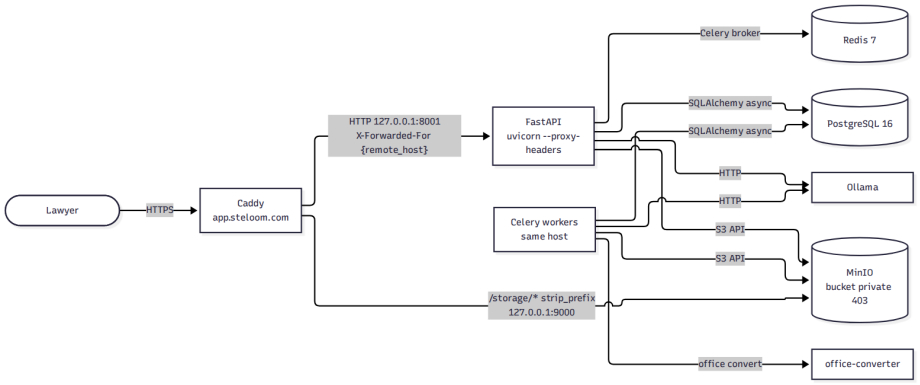
What this document covers: system context, in-house vs 3rd-party components, LLM architecture (model, fine-tuning, local vs external), the document → DD Grid path, versioning & reproducibility, team & ownership, manual vs automated operations, technical debt plan, and known limitations.

What it does not cover: product narrative and market positioning (see `Steloom_Product_Overview.md` v1.1), AI quality measurements and honest limitations (see `Steloom_AI_Quality_and_Limitations.md`), full risk register (see `QUALITY_AND_RISKS.md` §6), threat model detail (see `internal/THREAT_MODEL.md`, v1.1).

---

2. System context

Deployment: single host, Docker infrastructure services (PostgreSQL, Redis, MinIO, office-converter) + host-level API/workers under systemd, Caddy as HTTPS reverse proxy at `app.steloom.com`. The current demo is deployed at HEAD `e1325f9` (2026-10-26T17:13:48 UTC), matching the audited baseline of `TECHNICAL_OVERVIEW.md`.



System context

Trust boundaries: - **User ↔ API:** HTTPS terminated by Caddy. Caddy overwrites client-supplied `X-Forwarded-For` with `{remote_host}`; uvicorn trusts only `127.0.0.1` (`--forwarded-allow-ips=127.0.0.1`) — login rate limit is per-client-IP, not a shared bucket. - **API ↔ internal services:** localhost only, no auth between API and PG/Redis/MinIO/ Ollama. Internal network assumed trusted (single host). - **Client documents:** untrusted input. Prompt injection defenses: compact `<UNTRUSTED_DOCUMENT_TEXT>` delimiters + security line in 3 prompt files (fixed 2026-10-26, E97). Residual LOW: delimiter escape not sanitized. - **`/storage/*` MinIO proxy:** bucket private (`403` on direct access); exposed as Caddy route (R-40 LOW, recommended removal for defense-in-depth). - **`/ws/*`:** dead Caddy block, no matching FastAPI endpoint (R-41 INFO, hygiene cleanup optional).

---

3. In-house vs 3rd-party

In-house (written for Steloom): the pipeline orchestration, the legal-domain logic, the API, and the frontend. ~14 major components:

Component	Responsibility
Pipeline orchestration	Celery stages, outbox pattern, stage ledger, stale reapers, finalize guards
Layout 15-layer wrapper	Quality gates, quarantine, monolingual projection, spatial marker recovery (over Docling)
Segmentation (`_segmenter/`, 11 files)	Boundary detection: 11 weighted signals, swarm protection, TOC/ catalog suppression (6 heuristics), purity recovery

Component	Responsibility
Structure / clause tree	FSM hierarchy builder, cross-reference graph, structure assessment gate
LLM clause detection	Hybrid merge (LLM + conservative numeric fallback), appendices trimming, global routing, list-intro invariant
Chunk planner (Phase 10)	3 modes: STRUCTURE_FIRST / HYBRID / LAYOUT_FALLBACK
Classification cascade L1–L4	Filename → header → semantic → LLM; generic-under-specific cap, log-normalized L2 scoring, multi-window L3 encoding, adaptive noise suppression
Check execution	Check runner, result semantics, grounding, anchor resolution, DD request rules
Retrieval engine	BM25 + dense + metadata fusion
PII tokenizer + encryption wrapper	Fernet encryption, RU/EN role map, reveal with pre-audit
DD Grid builder	`dd_grid_v1_builder` + `deal_review_service` + risk-aware cells
Instruction snapshot + versioning	Two-phase freeze, strict mode, reproducibility flags
Export lifecycle	Excel / Word / JSON, lifecycle audit
Frontend	React + AG Grid; DD Grid V1 drawer, QC, admin

Plus API layer, audit middleware, rate-limit wrapper, observability (`/metrics` for API only — worker `/metrics` not implemented, R-32).

3rd-party services (external, not in code):

Service	Version	Role
PostgreSQL	16	Primary database
Redis	7	Celery broker, rate-limit storage, cache

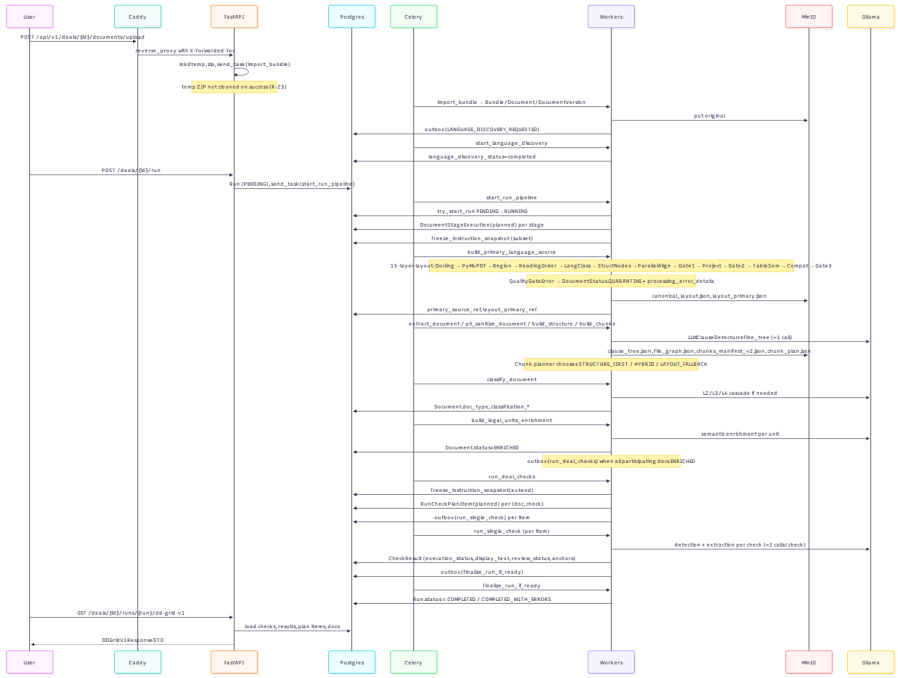
Service	Version	Role
MinIO	S3-compatible	Object storage (bucket private)
Ollama	HTTP API	LLM inference server (local)
LibreOffice	via `office-converter` Docker (python:3.11-slim + LO + fonts-noto-cjk + ru/zh/ar locales)	DOCX/XLSX/PPTX → PDF; isolated microservice, non-root `appuser`, per-request `profile_dir`, PDF quality validation via pdfplumber
Tesseract	in-process (eng/rus/deu/fra/tur/ara)	OCR for PDF images
Docling	2.121.0 (family: core 2.92.0, ibm-models 3.14.0, parse 7.15.0)	PDF layout extraction (in-process Python lib)

3rd-party Python libraries (~40, in code): FastAPI 0.115.6, uvicorn 0.34.0, SQLAlchemy 2.0.36 async + asyncpg 0.30.0 + Alembic 1.14.1, Celery 5.4.0, pydantic 2.10.4, sentence-transformers 3.3.1 + transformers 4.49.0 + torch 2.5.1+cpu (install-profile selects CPU/GPU), pdfplumber 0.11.4, pdf2image 1.17.0, pytesseract 0.3.13, PyMuPDF 1.28.2, cryptography 44.0.0, natasha 1.6.0, langdetect 1.0.9, lingua 2.0.2, rank-bm25, rapidfuzz, thefuzz, python-Levenshtein, prometheus-client 0.21.0, opentelemetry 1.28.2, boto3, openpyxl, xlsxwriter, python-docx, bcrypt, PyJWT, tiktoken, jsonschema, ruamel.yaml. **No in-house fork of any 3rd-party library.**

office-converter as an isolated microservice (own `requirements.txt`: fastapi 0.115.0, uvicorn 0.30.6, pydantic 2.8.2, starlette 0.38.2, pdfplumber 0.11.4): defense-in-depth for LibreOffice — non-root, per-request isolated profile, 100 MB max file, 14-extension whitelist, 180s timeout, PDF page/char/replacement-char/language validation, graceful shutdown, background cleanup. LibreOffice is treated as an untrusted parser, not called in-process.

---

4. Document → DD Grid path



Document → DD Grid path

Observed at E102 (2026-10-26, dev, synthetic 18-page contract `Sample_Contract.DOCX`, doc_type `contract_1.6_real_estate`, classification confidence 0.95): full sequence executed in **17.5 min** on GPU (RTX 5060 Ti, 49/49 layers offloaded) with `qwen2.5:14b`; 21 checks scheduled / 21 completed; 42 validated span anchors (34 `exact_span` + 8 `fuzzy_span`) + 19 `clause_only`; 37 LLM calls (~148k prompt / ~17.6k completion tokens); full lifecycle in `audit_logs` (16 action types from IMPORT → ANALYSIS_COMPLETED).

Second run (E105, dev, post-R-33/R-49/R-03/R-52 fixes): same synthetic contract, **15.2 min**, 21/21 checks, 43 validated anchors (35 exact + 8 fuzzy), 46 LLM calls. Confirms fixes did not break pipeline.

Caveat — two check-scheduling paths: batch (`run_deal_checks`, guarded by unique `Job`) and per-doc (`run_document_checks`, no `Job`). Both use `RunCheckPlanItem.create_planned`; unique partial indexes exist (migration `bc56177ec084`); `IntegrityError` not caught (R-08 LOW). Concurrent-run guard: partial unique index `uq_runs_one_active_per_deal WHERE status IN ('pending','running')` (migration `bf78307e1293`, R-33 CLOSED) — second concurrent `POST /deals/{id}/run` → `409 Conflict` + `X-Active-Run-Id` header (curl-verified E106; also on `/playbook/rebuild-and-rerun`, R-52 CLOSED).

E2E evidence is single-document. Multi-document orchestration exists and is exercised; cross-document reasoning (comparing clauses across documents) is not claimed as a validated capability — cross-document infrastructure is established but not yet fully utilized in the end-to-end evidence.

---

5. LLM architecture

Provider: `ollama` (local, JSON mode via `format=json`) is the production path. Alternatives: `openai`, `llamacpp` (GBNF, `Semaphore(1)`), `none`. In production, **Ollama local-only — no external API calls; data never leaves the client's infrastructure.** OpenAI provider exists in code but is not the production path; it would be a deliberate configuration change, not a default.

Model: `qwen2.5:14b` — **base model, no fine-tuning.** No Modelfile, no training data, no PEFT/LoRA adapter in the repository. All quality comes from prompt engineering + retrieval + conservative fallbacks (numeric-only clause fallback, grounding score, anchor resolution). A documented `qwen25-legal` name appears in the Makefile and `llama3.1` in the config default, but the observed runtime at E102/E105 is `qwen2.5:14b` — this is the honest state; model parity caveat applies to accuracy claims.

Runtime config (demo `.env`, E98): `LLM_CONTEXT_LIMIT=12288` (code default 32768), `LLM_MAX_TOKENS=256`, `LLM_SAFETY_MARGIN_TOKENS=512`. L4 worst-case fragment budget verified: `skeleton_tokens=3778`, `fragment_budget=7756`, overhead ratio 32.8% — sufficient. At `LLM_CONTEXT_LIMIT=4096` the fragment budget would floor at 300 (L4 near-useless); 12288 is a deliberate CPU-latency tradeoff.

Call sites (~50 per 23-check doc; observed 37 at E102 for 21 checks): extraction LLM (20), result presentation translation (12), run summary (2), clause detection (1), semantic enrichment (1), classification L4 (1), detection LLM (0 at E102 — rules-only). Detection uses `temperature=0.0`, `response_format="json_object"`, retries with backoff, `_salvage_partial_json` (3 passes) on structured output.

Grounding: token-overlap score; `exact` = 1.0; `<0.1` → suppressed; `0.1`–`0.3` → cap 0.7; `≥0.3` → anchor. Grounding suppresses weak evidence — it does not eliminate hallucinations; it is a mitigation, not a defense.

Prompt injection: compact `<UNTRUSTED_DOCUMENT_TEXT>` delimiters + security line applied 2026-10-26 to 3 prompt files (`generic_presence.txt`, `classify_document.txt`, `clause_detection.txt`). `classify_document.txt` additionally has ChatML system/user separation. Residual LOW: delimiter escape not sanitized (full closure in `_render_prompt` ~2h, deferred). Clause detection has a conservative numeric-only fallback that bounds hallucinated clause numbers.

GPU default (deployed): RTX 5060 Ti 16GB, CUDA 13.2, `torch 2.13.0+cu130`, Ollama 100% GPU (49/49 layers offloaded). Declared CPU profile lives in `requirements.txt` (`torch==2.5.1+cpu`); GPU install via `make install-runtime-gpu`. The 15–17 min wall-clock for 18-page / 21-check is dominated by non-LLM stages (Docling layout, OCR, segmentation, office-converter) — LLM inference is a fraction.

---

6. Office-converter microservice

LibreOffice is treated as an untrusted parser and isolated in its own FastAPI service (`/srv/steloom-dev/office-converter`), separate from the main app. Own `requirements.txt` (fastapi 0.115.0, uvicorn 0.30.6, pydantic 2.8.2, starlette 0.38.2, pdfplumber 0.11.4). Docker base `python:3.11-slim` + LibreOffice + `fonts-noto-cjk` + ru/zh/ar locales, non-root `appuser`.

Defense-in-depth per conversion: filename sanitization, 100 MB max file, 14-extension whitelist, per-request isolated `profile_dir` (no shared LibreOffice user profile), 180s timeout, `--headless --nologo --norestore`, PDF quality validation via pdfplumber (pages, extracted chars, replacement-char ratio, language detection cyrillic/arabic/cjk/latin), graceful shutdown via signal handlers, background cleanup. Endpoints: `/health`, `/ready`, `/metrics`, `/convert`, `/convert/debug` (`APP_VERSION 2.1.0`).

---

7. Versioning & reproducibility

Three separately versioned things, plus a frozen snapshot per run:

Layer	Frozen in run	Mechanism
Model	`Run.model_config_id`	`ModelConfig` DB entity
Playbook	`Run.playbook_version_id`	

Layer	Frozen in run	Mechanism
		`PlaybookVersion` (`semver`, `compiled_checks`)
Instruction snapshot	`Run.instruction_snapshot_*` + `snapshot_schema_version`	two-phase freeze
Result	`CheckResult` + `CheckResultAnchor` + `CheckResultPresentation`	anchor hashes

Strict mode (`>=1`) forbids filesystem fallback → `ConfigurationIntegrityError`. `compiled_checks` is the frozen check composition for the run. Model config is a DB entity; the run freezes `model_config_id`. Each anchor carries hashes + `primary_anchor_id`.

Reproducibility: a run with a valid instruction snapshot + published `PlaybookVersion` + `ModelConfig` is reproducible in principle (same inputs → same check composition, same prompts). **Legacy runs** with `instruction_snapshot_* = NULL` are marked `is_reproducible=False` — model/playbook may have changed since. Known caveat: `pipeline_strategy` depends only on the model, not the playbook, so a playbook change does not trigger `FULL_RERUN` (owner-intent accepted, S-04).

Not claimed: bit-for-bit reproducibility of LLM output (temperature 0.0 reduces but does not eliminate nondeterminism across model versions). The snapshot guarantees “same configuration”, not “same tokens”.

---

8. Team & ownership

Founders (2): - **Founder 1 (business):** principle business-logic ideas; initial prototype built via vibe-coding. The prototype was then rewritten — it is not the production codebase. - **Founder 2 (CTO):** technical architecture and configuration; rewrote the prototype into the current codebase; sole current engineer on the code.

Contractors (2 outsourced engineers): engaged under specific implementation tasks and corrected code where needed; not full-time; not a standing engineering team. The codebase is currently maintained by the CTO.

Engineering is 100% in-house (no outsourced ownership of core components, no in-house fork of a 3rd-party library). Post-funding plan: hire an engineering team; specifics belong in the pitch, not this document.

---

9. Manual vs automated operations

Automated: the whole document → DD Grid pipeline (Celery stages, outbox dispatch every 5s, retries with backoff, DLQ on `PermanentError`/`SoftTimeLimit`, stale-execution reaper every 600s, stale-run reaper every 1800s, finalize guards, 3 layout quality gates, concurrent-run 409 guard).

Hybrid today: - **Playbook configuration** — clients build playbooks in **Playbook Studio** (self-serve selection from a library of 900+ checks authored by Steloom's domain experts). During onboarding, Steloom provides hands-on support to align the selected checks with the client's compliance matrix; the resulting composition is frozen as a `PlaybookVersion`. **AI-assisted composition** (drafting a playbook from a compliance matrix) is a roadmap item, not current.

Manual today: - **Deploy** — `deploy/deploy-demo.sh` (flock, backup, `rsync -a --delete` whitelist, `alembic upgrade`, `npm run build`, health checks, auto-gen `.deploy-meta.json`). Pre-flight `verify_systemd_units_contain_q6()` aborts on rate-limit regression. - **DB migrations** — Alembic, run manually in the deploy script. - **DLQ review, reclassifications, run monitoring** — operator-driven; no self-healing UI. - **Backups** — rotation automated (`rotate_backups()`, 30d + keep 10; currently 12 dirs, 4.4 GB), but restore is manual; no rollback script (R-28 LOW-MEDIUM).

---

10. Technical debt & roadmap

P1 items (target: before first paying customer), from `OPEN_WORK.md` / `QUALITY_AND_RISKS.md` §10:

Item	Why it matters
R-01 JWT revocation (`password_changed_at`, TTL 30min, refresh)	Deactivation/demotion/password change only effective at 8h token expiry today

Item	Why it matters
R-02 audit gaps (login, upload-identity, download, admin-users)	Compliance trail completeness
R-10 PII key rotation	Old mappings unreadable after key change today
R-18 `_truncated` badge in UI	Partial JSON shown as complete today
R-22 CI test workflow	Tests do not run in CI today (only `pip-audit`)
R-28 rollback script	Manual rollback only

P2 (post-first-paying): R-05 rate-limiter fallback, R-31 `LAYOUT_QUARANTINED` audit event, R-32 worker `/metrics` (LLM alerts currently sleeping), R-34 mode-C alert, R-08 `IntegrityError` catch, R-17 residual delimiter sanitization.

Current open risk posture: 51 risks, **0 HIGH open**, 9 CLOSED with evidence (R-03, R-07, R-33, R-38, R-39, R-44, R-46, R-49, R-52). **R-49 (HIGH, `model_configs` unauth) was found during live verification and is CLOSED as of threat model v1.1 (E106).** Open includes R-50 MEDIUM (Content-Disposition CRLF), R-51 LOW (public `document-types` GET), R-24 LOW-MEDIUM (HEIC/WebP magic → VALID), R-53 LOW (test gap), R-45 LOW (test isolation).

---

11. Known limitations

- **Single synthetic document** verified end-to-end (E102/E105, 18 pp.). Not a benchmark of accuracy, not representative of all doc types, no multi-document cross-reasoning validation.
- **15–17 min wall-clock (measured on GPU)** per 18-page / 21-check document — dominated by non-LLM stages (Docling layout, OCR, segmentation, office-converter), not LLM inference.
- **Base model, no fine-tuning** — `qwen2.5:14b`; model parity caveat (documented `qwen25-legal` not observed at runtime).
- **No accuracy benchmark** — see `Steloom_AI_Quality_and_Limitations.md` for what is and isn't measured, and the evaluation plan.
- **No CVE audit / dependency scanning beyond `pip-audit`** in CI.
- **Playbook composition is hybrid** — Playbook Studio is self-serve for check selection; AI-assisted composition and full self-serve onboarding are roadmap (§9).

- **Worker `/metrics` not implemented** — LLM alerts sleeping (R-32).
- **Demo deployed via rsync** without a git commit — authoritative version is `/srv/steloom-demo/.deploy-meta.json` (dev_head=`e1325f9`, deployed 2026-10-26T17:13:48 UTC), not `git rev-parse HEAD` in the demo dir.

---

12. Out of scope (of this document)

- **Full AI pipeline detail** (L1/L2/L3 scoring formulas, grounding, anchor resolution) — `TECHNICAL_OVERVIEW.md` §7.
- **Data model ER diagram** — `TECHNICAL_OVERVIEW.md` §8.
- **~70 structure submodule files** (`_element_classifier/`, `_heading_builder/`, `_hierarchy_builder/`, `semantic_enrichment/`, `coherence/`, `cohesion/`, etc.) — not read in the audit; not required for architecture-level diligence.
- **Frontend beyond DD Grid V1** — not covered.
- **Threat model detail** — `internal/THREAT_MODEL.md` (18 threats, 0 HIGH open).
- **Full risk register** — `QUALITY_AND_RISKS.md` §6.
- **Product narrative / market** — `Steloom_Product_Overview.md` v1.1.

End of Steloom_Architecture. Snapshot `f22e3ba`; HEAD at completion `e1325f9`; demo deployed at `e1325f9` 2026-10-26T17:13 UTC. In-house vs 3rd-party per `TECHNICAL_OVERVIEW.md` §3–§4; LLM per §7; versioning per §7/§8; debt per `OPEN_WORK.md` / `QUALITY_AND_RISKS.md` §10. Evidence E99–E106. 51 risks, 0 HIGH open, 9 CLOSED. Not an independent audit — companion to the tech DD pack.